

forward-ocean-ee6a66af

Current Risk Summary report

Wed May 06 2026 21:33:55 GMT+0000 (Coordinated Universal Time)

Project description: *No description*

Filtered by: Critical risk High risk Medium risk Low risk Very Low risk

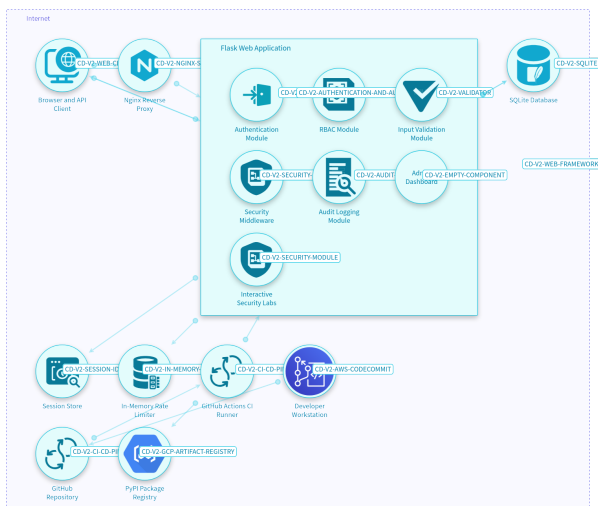
i This report only includes threats that match the filters above.

Unique ID: forward-ocean-ee6a66af

Owner: Usman Ali

Workflow state: Draft

Tags: jeff-generated



Content menu

[Current risk summary](#)

[Components](#)

[Accepted Risks](#)

[Current Risks](#)

- [Audit Logging Module](#)
- [Authentication Module](#)
- [Browser and API Client](#)
- [Developer Workstation](#)
- [Flask Web Application](#)
- [GitHub Actions CI Runner](#)
- [GitHub Repository](#)
- [In-Memory Rate Limiter](#)
- [Input Validation Module](#)
- [Interactive Security Labs](#)
- [Nginx Reverse Proxy](#)
- [PyPI Package Registry](#)
- [RBAC Module](#)
- [Security Middleware](#)
- [Session Store](#)
- [SQLite Database](#)

Current Risk summary

Inherent risk description: The Inherent Risk before countermeasures were applied.

• **Risk Rating:** 68.61363983154297%  High

The Current Risk description (the risk we are at now): The Current Risk is based on the current implementation status of the countermeasures and test results.

• **Risk Rating:** 68.61363983154297%  High

Projected Risk description: The Projected Risk is the level of risk that would be reached should the required countermeasures be implemented.

• **Risk Rating:** 68.61363983154297%  High

Components

- Admin Dashboard
- Audit Logging Module
- Authentication Module
- Browser and API Client
- Developer Workstation
- Flask Web Application
- GitHub Actions CI Runner
- GitHub Repository
- In-Memory Rate Limiter
- Input Validation Module
- Interactive Security Labs
- Nginx Reverse Proxy
- PyPI Package Registry
- RBAC Module
- Security Middleware
- Session Store
- SQLite Database

Accepted Risks

No data

Current Risks

Component: Audit Logging Module

 **Use case:** Repudiation

CRT1. Threat name: Attackers rely on the lack of monitoring and timely response to achieve their goals without being detected

- Inherent risk:**  High
- Current risk:**  High
- Projected risk:**  High
- State:** Exposed
- CR1. Countermeasure name:** Ensure high-value transactions have an audit trail with integrity controls to prevent tampering or deletion
 - Status:** RECOMMENDED
- CR2. Countermeasure name:** Log and reject all data validation failures
 - Status:** RECOMMENDED
- CR3. Countermeasure name:** Ensure that logs are generated in a format that log management solutions can easily consume
 - Status:** RECOMMENDED

 **Use case:** Tampering

CRT2. Threat name: The attacker injects, manipulates or forges malicious log entries in the log file, allowing them to mislead a log audit, cover traces of attack, or perform log injection attacks

- Inherent risk:**  Critical
- Current risk:**  Critical
- Projected risk:**  Critical
- State:** Exposed
- CR4. Countermeasure name:** Develop a log retention policy
 - Status:** RECOMMENDED
- CR5. Countermeasure name:** Log details of user actions within the system
 - Status:** RECOMMENDED

Component: Authentication Module

 **Use case:** Elevation of Privilege

CRT3. Threat name: Attackers access the system taking advantage of broken authentication

- Inherent risk:**  Critical
- Current risk:**  Critical
- Projected risk:**  Critical
- State:** Exposed
- CR6. Countermeasure name:** Implement server-side access control checks
 - Status:** RECOMMENDED

CRT4. Threat name: Attackers exploit flaws in access control systems

- Inherent risk:**  Critical
- Current risk:**  Critical
- Projected risk:**  Critical
- State:** Exposed
- CR7. Countermeasure name:** Implement Multi-Factor Authentication (MFA)
 - Status:** RECOMMENDED
- CR8. Countermeasure name:** Implement secure session management
 - Status:** RECOMMENDED

 **Use case:** Tampering

CRT5. Threat name: Attackers capitalize on security misconfigurations

- Inherent risk:**  Critical
- Current risk:**  Critical
- Projected risk:**  Critical
- State:** Exposed
- CR9. Countermeasure name:** Conduct regular security audits and reviews
 - Status:** RECOMMENDED

 **Use case:** Information Disclosure

CRT6. Threat name: Attackers get access to sensitive data

- Inherent risk:**  Critical
- Current risk:**  Critical
- Projected risk:**  Critical
- State:** Exposed
- CR10. Countermeasure name:** Use encryption to protect sensitive data

- **Status:** RECOMMENDED

Component: Browser and API Client

 **Use case:** Spoofing

- CRT7. Threat name:** Clickjacking
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR11. Countermeasure name:** Detect and block UI redressing attempts
 - **Status:** RECOMMENDED

 **Use case:** Tampering

- CRT8. Threat name:** Client-side insecure data storage
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR12. Countermeasure name:** Prevent storage of sensitive data on the client
 - **Status:** RECOMMENDED
- CRT9. Threat name:** Cross-site scripting
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR13. Countermeasure name:** Avoid unsafe DOM manipulation and isolate untrusted scripts
 - **Status:** RECOMMENDED
- CRT10. Threat name:** Man-in-the-middle attacks
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR14. Countermeasure name:** Ensure secure communication and validate external resources
 - **Status:** RECOMMENDED

Component: Developer Workstation

 **Use case:** Tampering

- CRT11. Threat name:** Code tampering
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR15. Countermeasure name:** Enable branch protection
 - **Status:** RECOMMENDED
- CRT12. Threat name:** Data loss during migration
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR16. Countermeasure name:** Implement backup and restoration procedures
 - **Status:** RECOMMENDED

 **Use case:** Information Disclosure

- CRT13. Threat name:** Unauthorized repository access
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR17. Countermeasure name:** Configure repository policies
 - **Status:** RECOMMENDED

Component: Flask Web Application

🔗 Use case: Tampering

- CRT14. Threat name:** Attackers craft and upload malicious files or inject malicious inputs, e.g., code/command execution
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR18. Countermeasure name:** Validate all user inputs including using built-in mechanisms
 - **Status:** RECOMMENDED

- CRT15. Threat name:** Attackers gain access to the application data, e.g., secrets
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR19. Countermeasure name:** Safeguard sensitive information
 - **Status:** RECOMMENDED

- CRT16. Threat name:** Attackers gain unauthorized access by manipulating input parameters, e.g., IDOR or mass assignment
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR20. Countermeasure name:** Implement proper object references and binding
 - **Status:** RECOMMENDED

🔗 Use case: Elevation of Privilege

- CRT17. Threat name:** Attackers craft input data to execute arbitrary SQL queries
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR21. Countermeasure name:** Implement SQLi protections, e.g., parameterized queries
 - **Status:** RECOMMENDED

- CRT18. Threat name:** Attackers gain access to the application or privileges in the environment
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR22. Countermeasure name:** Implement proper access controls and authorization checks
 - **Status:** RECOMMENDED

- CRT19. Threat name:** Attackers gain access to the system using a vulnerable framework or dependency
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR23. Countermeasure name:** Use up-to-date framework and well-tested routines and dependencies
 - **Status:** RECOMMENDED

- CRT20. Threat name:** Attackers take control of a user's session
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR24. Countermeasure name:** Implement secure session management including using built-in mechanisms
 - **Status:** RECOMMENDED

🔗 Use case: Spoofing

- CRT21. Threat name:** Attackers craft links to execute malicious actions (CSRF)
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR25. Countermeasure name:** Use anti-CSRF tokens and built-in mechanisms
 - **Status:** RECOMMENDED

🔗 Use case: Information Disclosure

- CRT22. Threat name:** Attackers gain data or access exploiting insecure configuration or defaults
- **Inherent risk:**  High

- **Current risk:** 🔴 High
- **Projected risk:** 🔴 High
- **State:** Exposed
- **CR26. Countermeasure name:** Review defaults and configuration files
 - **Status:** RECOMMENDED

Component: GitHub Actions CI Runner

🔗 **Use case:** Elevation of Privilege

CRT23. Threat name: Bypass of authorized CI/CD pipelines

- **Inherent risk:** 🔴 High
- **Current risk:** 🔴 High
- **Projected risk:** 🔴 High
- **State:** Exposed
- **CR27. Countermeasure name:** Audit repository webhooks to prevent external trigger points
 - **Status:** RECOMMENDED
- **CR28. Countermeasure name:** Restrict repository access to the CI/CD service account
 - **Status:** RECOMMENDED

CRT24. Threat name: Bypass of mandatory security scanning

- **Inherent risk:** 🔴 Critical
- **Current risk:** 🔴 Critical
- **Projected risk:** 🔴 Critical
- **State:** Exposed
- **CR29. Countermeasure name:** Configure admission controllers to reject artifacts without scan metadata
 - **Status:** RECOMMENDED
- **CR30. Countermeasure name:** Enforce blocking status checks on pull requests
 - **Status:** RECOMMENDED

CRT25. Threat name: Excessive pipeline permissions

- **Inherent risk:** 🔴 High
- **Current risk:** 🔴 High
- **Projected risk:** 🔴 High
- **State:** Exposed
- **CR31. Countermeasure name:** Automate rotation of short-lived service tokens
 - **Status:** RECOMMENDED
- **CR32. Countermeasure name:** Apply granular least privilege RBAC roles
 - **Status:** RECOMMENDED

CRT26. Threat name: Insecure build environment

- **Inherent risk:** 🔴 High
- **Current risk:** 🔴 High
- **Projected risk:** 🔴 High
- **State:** Exposed
- **CR33. Countermeasure name:** Provision ephemeral runners for isolated tasks
 - **Status:** RECOMMENDED
- **CR34. Countermeasure name:** Implement network egress filtering
 - **Status:** RECOMMENDED

🔗 **Use case:** Tampering

CRT27. Threat name: Dependency confusion and poisoning

- **Inherent risk:** 🔴 Critical
- **Current risk:** 🔴 Critical
- **Projected risk:** 🔴 Critical
- **State:** Exposed
- **CR35. Countermeasure name:** Enforce dependency pinning with hash verification
 - **Status:** RECOMMENDED
- **CR36. Countermeasure name:** Configure private package registries for builds
 - **Status:** RECOMMENDED

CRT28. Threat name: Lack of artifact provenance

- **Inherent risk:** 🔴 High
- **Current risk:** 🔴 High
- **Projected risk:** 🔴 High
- **State:** Exposed
- **CR37. Countermeasure name:** Automate SBOM generation
 - **Status:** RECOMMENDED
- **CR38. Countermeasure name:** Enable cryptographic artifact signing
 - **Status:** RECOMMENDED

CRT29. Threat name: Unauthorized pipeline configuration changes

- **Inherent risk:** 🔴 High
- **Current risk:** 🔴 High

- **Projected risk:** ⬆ High
- **State:** Exposed
- **CR39. Countermeasure name:** Mandate peer reviews for configuration changes
 - **Status:** RECOMMENDED
- **CR40. Countermeasure name:** Require GPG signed commits for definitions
 - **Status:** RECOMMENDED

- CRT30. Threat name:** Usage of unauthorized container images
- **Inherent risk:** ⬆ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆ High
 - **State:** Exposed
 - **CR41. Countermeasure name:** Enforce registry allow-lists in container orchestration
 - **Status:** RECOMMENDED
 - **CR42. Countermeasure name:** Scan container images for compliance during the CI/CD build phase
 - **Status:** RECOMMENDED

🔗 **Use case:** Spoofing

- CRT31. Threat name:** Insecure secret management
- **Inherent risk:** ⬆ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆ High
 - **State:** Exposed
 - **CR43. Countermeasure name:** Implement centralized secret management services
 - **Status:** RECOMMENDED
 - **CR44. Countermeasure name:** Integrate automated secret scanning in pipelines
 - **Status:** RECOMMENDED

Component: GitHub Repository

🔗 **Use case:** Elevation of Privilege

- CRT32. Threat name:** Bypass of authorized CI/CD pipelines
- **Inherent risk:** ⬆ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆ High
 - **State:** Exposed
 - **CR45. Countermeasure name:** Audit repository webhooks to prevent external trigger points
 - **Status:** RECOMMENDED
 - **CR46. Countermeasure name:** Restrict repository access to the CI/CD service account
 - **Status:** RECOMMENDED
- CRT33. Threat name:** Bypass of mandatory security scanning
- **Inherent risk:** 🔴 Critical
 - **Current risk:** 🔴 Critical
 - **Projected risk:** 🔴 Critical
 - **State:** Exposed
 - **CR47. Countermeasure name:** Configure admission controllers to reject artifacts without scan metadata
 - **Status:** RECOMMENDED
 - **CR48. Countermeasure name:** Enforce blocking status checks on pull requests
 - **Status:** RECOMMENDED
- CRT34. Threat name:** Excessive pipeline permissions
- **Inherent risk:** ⬆ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆ High
 - **State:** Exposed
 - **CR49. Countermeasure name:** Apply granular least privilege RBAC roles
 - **Status:** RECOMMENDED
 - **CR50. Countermeasure name:** Automate rotation of short-lived service tokens
 - **Status:** RECOMMENDED
- CRT35. Threat name:** Insecure build environment
- **Inherent risk:** ⬆ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆ High
 - **State:** Exposed
 - **CR51. Countermeasure name:** Implement network egress filtering
 - **Status:** RECOMMENDED
 - **CR52. Countermeasure name:** Provision ephemeral runners for isolated tasks
 - **Status:** RECOMMENDED

🔗 **Use case:** Tampering

- CRT36. Threat name:** Dependency confusion and poisoning
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR53. Countermeasure name:** Enforce dependency pinning with hash verification
 - **Status:** RECOMMENDED
 - **CR54. Countermeasure name:** Configure private package registries for builds
 - **Status:** RECOMMENDED

- CRT37. Threat name:** Lack of artifact provenance
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR55. Countermeasure name:** Enable cryptographic artifact signing
 - **Status:** RECOMMENDED
 - **CR56. Countermeasure name:** Automate SBOM generation
 - **Status:** RECOMMENDED

- CRT38. Threat name:** Unauthorized pipeline configuration changes
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR57. Countermeasure name:** Mandate peer reviews for configuration changes
 - **Status:** RECOMMENDED
 - **CR58. Countermeasure name:** Require GPG signed commits for definitions
 - **Status:** RECOMMENDED

- CRT39. Threat name:** Usage of unauthorized container images
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR59. Countermeasure name:** Scan container images for compliance during the CI/CD build phase
 - **Status:** RECOMMENDED
 - **CR60. Countermeasure name:** Enforce registry allow-lists in container orchestration
 - **Status:** RECOMMENDED

 **Use case:** Spoofing

- CRT40. Threat name:** Insecure secret management
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR61. Countermeasure name:** Implement centralized secret management services
 - **Status:** RECOMMENDED
 - **CR62. Countermeasure name:** Integrate automated secret scanning in pipelines
 - **Status:** RECOMMENDED

Component: In-Memory Rate Limiter

 **Use case:** Tampering

- CRT41. Threat name:** Attackers inject malicious code into the database
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR63. Countermeasure name:** Implement parameterized queries with prepared statements
 - **Status:** RECOMMENDED
 - **CR64. Countermeasure name:** Validate and sanitize all incoming data against predefined schemas
 - **Status:** RECOMMENDED

 **Use case:** Repudiation

- CRT42. Threat name:** Attackers leverage inadequate logging and monitoring to conduct their activities unnoticed
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR65. Countermeasure name:** Implement continuous monitoring of critical systems and networks

- **Status:** RECOMMENDED
- **CR66. Countermeasure name:** Implement centralized comprehensive logging
- **Status:** RECOMMENDED

🔗 **Use case:** Information Disclosure

- CRT43. Threat name:** Attackers take advantage of data exposure vulnerabilities
- **Inherent risk:** 🔴 Critical
 - **Current risk:** 🟠 Critical
 - **Projected risk:** 🔴 Critical
 - **State:** Exposed
 - **CR67. Countermeasure name:** Establish and enforce granular access controls
 - **Status:** RECOMMENDED
 - **CR68. Countermeasure name:** Enforce encryption for all sensitive data
 - **Status:** RECOMMENDED

Component: Input Validation Module

🔗 **Use case:** Tampering

- CRT44. Threat name:** Attackers bypass the validation process
- **Inherent risk:** 🔴 Critical
 - **Current risk:** 🟠 Critical
 - **Projected risk:** 🔴 Critical
 - **State:** Exposed
 - **CR69. Countermeasure name:** Harden the input validation mechanisms, setup, and pipeline
 - **Status:** RECOMMENDED

- CRT45. Threat name:** Attackers inject malicious content, e.g., SQL injection
- **Inherent risk:** 🔴 Critical
 - **Current risk:** 🟠 Critical
 - **Projected risk:** 🔴 Critical
 - **State:** Exposed
 - **CR70. Countermeasure name:** Proper use of sanitization and validation mechanisms
 - **Status:** RECOMMENDED

🔗 **Use case:** Denial of Service

- CRT46. Threat name:** Attackers exploit performance bottlenecks or vulnerable validation processing functionality
- **Inherent risk:** 🔴 Critical
 - **Current risk:** 🟠 Critical
 - **Projected risk:** 🔴 Critical
 - **State:** Exposed
 - **CR71. Countermeasure name:** Optimize validation steps
 - **Status:** RECOMMENDED

Component: Interactive Security Labs

🔗 **Use case:** Tampering

- CRT47. Threat name:** Attacker exploit misconfiguration and vulnerable third-party
- **Inherent risk:** 🔴 High
 - **Current risk:** 🟠 High
 - **Projected risk:** 🔴 High
 - **State:** Exposed
 - **CR72. Countermeasure name:** Comprehensive configuration hardening and dependency auditing
 - **Status:** RECOMMENDED

- CRT48. Threat name:** Attackers execute injection attacks
- **Inherent risk:** 🔴 High
 - **Current risk:** 🟠 High
 - **Projected risk:** 🔴 High
 - **State:** Exposed
 - **CR73. Countermeasure name:** Use parameterized queries and input validation
 - **Status:** RECOMMENDED

🔗 **Use case:** Spoofing

- CRT49. Threat name:** Attackers gain elevated privileges or unauthorized access
- **Inherent risk:** 🔴 High
 - **Current risk:** 🟠 High
 - **Projected risk:** 🔴 High
 - **Status:** RECOMMENDED

- **State:** Exposed
- **CR74. Countermeasure name:** Implement multi-layered security for authentication and access control
- **Status:** RECOMMENDED

🔗 **Use case:** Information Disclosure

CRT50. Threat name: Attackers gather useful information from inadequate error handling

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR75. Countermeasure name:** Implement generic error messages and proper exception handling
- **Status:** RECOMMENDED

CRT51. Threat name: Attackers take advantage of insecure communication channels and unprotected sessions

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR76. Countermeasure name:** Implement comprehensive secure communication and session management protocols
- **Status:** RECOMMENDED

CRT52. Threat name: Attackers take advantage of weak encryption of sensitive data

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR77. Countermeasure name:** Implement and maintain advanced encryption standards with effective key management
- **Status:** RECOMMENDED

🔗 **Use case:** Denial of Service

CRT53. Threat name: Attackers perform a Denial of Service (DoS)

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR78. Countermeasure name:** Implement rate limiting and resource allocation
- **Status:** RECOMMENDED

🔗 **Use case:** Repudiation

CRT54. Threat name: Lack of evidences of misuse due to insufficient auditing and logging and poor log protection

- **Inherent risk:** 🟡 Medium
- **Current risk:** 🟡 Medium
- **Projected risk:** 🟡 Medium
- **State:** Exposed
- **CR79. Countermeasure name:** Implement comprehensive logging and monitoring with log integrity measures
- **Status:** RECOMMENDED

Component: Nginx Reverse Proxy

🔗 **Use case:** Tampering

CRT55. Threat name: Exploited unused NGINX modules

- **Inherent risk:** 🔴 Critical
- **Current risk:** 🔴 Critical
- **Projected risk:** 🔴 Critical
- **State:** Exposed
- **CR80. Countermeasure name:** Reconfigure NGINX with only necessary modules
- **Status:** RECOMMENDED

CRT56. Threat name: Exposed to attacks through unsafe HTTP methods

- **Inherent risk:** 🔴 Critical
- **Current risk:** 🔴 Critical
- **Projected risk:** 🔴 Critical
- **State:** Exposed
- **CR81. Countermeasure name:** Restrict HTTP methods
- **Status:** RECOMMENDED

CRT57. Threat name: Potential vulnerabilities due to outdated software

- **Inherent risk:** 🔴 Critical
- **Current risk:** 🔴 Critical

- **Projected risk:** 🚩 Critical
- **State:** Exposed
- **CR82. Countermeasure name:** Regularly update NGINX
 - **Status:** RECOMMENDED

🔗 **Use case:** Information Disclosure

- CRT58. Threat name:** Insecure transmission of data
- **Inherent risk:** 🚩 Critical
 - **Current risk:** 🚩 Critical
 - **Projected risk:** 🚩 Critical
 - **State:** Exposed
 - **CR83. Countermeasure name:** Implement modern SSL/TLS protocols and disable weak protocols
 - **Status:** RECOMMENDED

- CRT59. Threat name:** Lack of security headers
- **Inherent risk:** 🚩 High
 - **Current risk:** 🚩 High
 - **Projected risk:** 🚩 High
 - **State:** Exposed
 - **CR84. Countermeasure name:** Implement appropriate security headers
 - **Status:** RECOMMENDED

- CRT60. Threat name:** Sensitive information leakage through server headers
- **Inherent risk:** 🚩 High
 - **Current risk:** 🚩 High
 - **Projected risk:** 🚩 High
 - **State:** Exposed
 - **CR85. Countermeasure name:** Remove unnecessary server headers
 - **Status:** RECOMMENDED

Component: PyPI Package Registry

🔗 **Use case:** Information Disclosure

- CRT61. Threat name:** Data exfiltration risks
- **Inherent risk:** 🚩 Critical
 - **Current risk:** 🚩 Critical
 - **Projected risk:** 🚩 Critical
 - **State:** Exposed
 - **CR86. Countermeasure name:** Implement VPC service controls
 - **Status:** RECOMMENDED

- CRT62. Threat name:** Unauthorized access to repositories
- **Inherent risk:** 🚩 High
 - **Current risk:** 🚩 High
 - **Projected risk:** 🚩 High
 - **State:** Exposed
 - **CR87. Countermeasure name:** Use identity and access management
 - **Status:** RECOMMENDED

🔗 **Use case:** Tampering

- CRT63. Threat name:** Vulnerable container images
- **Inherent risk:** 🚩 Critical
 - **Current risk:** 🚩 Critical
 - **Projected risk:** 🚩 Critical
 - **State:** Exposed
 - **CR88. Countermeasure name:** Enable automatic vulnerability scanning
 - **Status:** RECOMMENDED

Component: RBAC Module

🔗 **Use case:** Elevation of Privilege

- CRT64. Threat name:** Attackers gain unauthorized access or elevated privileges, e.g., via stolen credentials, cookies, or tokens
- **Inherent risk:** 🚩 High
 - **Current risk:** 🚩 High
 - **Projected risk:** 🚩 High
 - **State:** Exposed
 - **CR89. Countermeasure name:** Use secure access control mechanisms
 - **Status:** RECOMMENDED

🔗 Use case: Tampering

- CRT65. Threat name:** Attackers inject malicious content, e.g., SQL queries, to manipulate or access data
- **Inherent risk:** ⬆️ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆️ High
 - **State:** Exposed
 - **CR90. Countermeasure name:** Input validation and sanitization
 - **Status:** RECOMMENDED

🔗 Use case: Information Disclosure

- CRT66. Threat name:** Attackers intercept or eavesdrop on sensitive information during transmission
- **Inherent risk:** ⬆️ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆️ High
 - **State:** Exposed
 - **CR91. Countermeasure name:** Enforce secure configuration and encryption
 - **Status:** RECOMMENDED

🔗 Use case: Denial of Service

- CRT67. Threat name:** Attackers use enumeration to discover valid user identifiers, potentially creating a Denial of Service (DoS) condition
- **Inherent risk:** ⬆️ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆️ High
 - **State:** Exposed
 - **CR92. Countermeasure name:** Rate limiting and proper resource management
 - **Status:** RECOMMENDED

🔗 Use case: Repudiation

- CRT68. Threat name:** Lack of evidences of misuse due to insufficient logging
- **Inherent risk:** 🟡 Medium
 - **Current risk:** 🟡 Medium
 - **Projected risk:** 🟡 Medium
 - **State:** Exposed
 - **CR93. Countermeasure name:** Create a policy and workflow for comprehensive logging and monitoring
 - **Status:** RECOMMENDED

Component: Security Middleware

🔗 Use case: Tampering

- CRT69. Threat name:** Attacker exploit misconfiguration and vulnerable third-party
- **Inherent risk:** ⬆️ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆️ High
 - **State:** Exposed
 - **CR94. Countermeasure name:** Comprehensive configuration hardening and dependency auditing
 - **Status:** RECOMMENDED

- CRT70. Threat name:** Attackers execute injection attacks
- **Inherent risk:** ⬆️ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆️ High
 - **State:** Exposed
 - **CR95. Countermeasure name:** Use parameterized queries and input validation
 - **Status:** RECOMMENDED

🔗 Use case: Spoofing

- CRT71. Threat name:** Attackers gain elevated privileges or unauthorized access
- **Inherent risk:** ⬆️ High
 - **Current risk:** 🔴 High
 - **Projected risk:** ⬆️ High
 - **State:** Exposed
 - **CR96. Countermeasure name:** Implement multi-layered security for authentication and access control
 - **Status:** RECOMMENDED

🔒 Use case: Information Disclosure

CRT72. Threat name: Attackers gather useful information from inadequate error handling

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR97. Countermeasure name:** Implement generic error messages and proper exception handling
- **Status:** RECOMMENDED

CRT73. Threat name: Attackers take advantage of insecure communication channels and unprotected sessions

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR98. Countermeasure name:** Implement comprehensive secure communication and session management protocols
- **Status:** RECOMMENDED

CRT74. Threat name: Attackers take advantage of weak encryption of sensitive data

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR99. Countermeasure name:** Implement and maintain advanced encryption standards with effective key management
- **Status:** RECOMMENDED

🔒 Use case: Denial of Service

CRT75. Threat name: Attackers perform a Denial of Service (DoS)

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR100. Countermeasure name:** Implement rate limiting and resource allocation
- **Status:** RECOMMENDED

🔒 Use case: Repudiation

CRT76. Threat name: Lack of evidences of misuse due to insufficient auditing and logging and poor log protection

- **Inherent risk:** 🟡 Medium
- **Current risk:** 🟡 Medium
- **Projected risk:** 🟡 Medium
- **State:** Exposed
- **CR101. Countermeasure name:** Implement comprehensive logging and monitoring with log integrity measures
- **Status:** RECOMMENDED

Component: Session Store

🔒 Use case: Denial of Service

CRT77. Threat name: Attackers execute Denial of Service (DoS) via session flooding

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR102. Countermeasure name:** Implement session management policies and rate limiting
- **Status:** RECOMMENDED

🔒 Use case: Information Disclosure

CRT78. Threat name: Attackers exploit session timeout mismanagement

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR103. Countermeasure name:** Implement session expiration and invalidation
- **Status:** RECOMMENDED

CRT79. Threat name: Attackers take advantage of unsecure data handling and communication

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High

- **State:** Exposed
- **CR104. Countermeasure name:** Implement end-to-end session data security practices
- **Status:** RECOMMENDED

🔗 Use case: Tampering

CRT80. Threat name: Attackers steal or manipulate session data via injection attacks

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR105. Countermeasure name:** Use comprehensive input handling security measures
- **Status:** RECOMMENDED

🔗 Use case: Spoofing

CRT81. Threat name: Attackers take advantage of predictable session tokens

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR106. Countermeasure name:** Secure session variable handling
- **Status:** RECOMMENDED
- **CR107. Countermeasure name:** Use strong session token generators
- **Status:** RECOMMENDED

🔗 Use case: Repudiation

CRT82. Threat name: Lack of evidences of misuse due to insufficient logging

- **Inherent risk:** 🟡 Medium
- **Current risk:** 🟡 Medium
- **Projected risk:** 🟡 Medium
- **State:** Exposed
- **CR108. Countermeasure name:** Implement comprehensive logging and monitoring
- **Status:** RECOMMENDED

Component: SQLite Database

🔗 Use case: Tampering

CRT83. Threat name: Attackers exploit outdated SQLite vulnerabilities

- **Inherent risk:** ⬆️ Critical
- **Current risk:** 🔴 Critical
- **Projected risk:** ⬆️ Critical
- **State:** Exposed
- **CR109. Countermeasure name:** Regularly update SQLite to the latest secure version
- **Status:** RECOMMENDED

CRT84. Threat name: Attackers inject malicious SQL commands via SQL injection

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR110. Countermeasure name:** Use parameterized queries and input validation
- **Status:** RECOMMENDED

CRT85. Threat name: Attackers tamper with data due to physical access to the database file

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR111. Countermeasure name:** Use full disk encryption and secure backup mechanisms
- **Status:** RECOMMENDED

🔗 Use case: Elevation of Privilege

CRT86. Threat name: Attackers gain unauthorized access due to insecure file permissions

- **Inherent risk:** ⬆️ High
- **Current risk:** 🔴 High
- **Projected risk:** ⬆️ High
- **State:** Exposed
- **CR112. Countermeasure name:** Enforce secure file permissions on the database file

- **Status:** RECOMMENDED

🔗 **Use case:** Information Disclosure

- CRT87. Threat name:** Data exposure through insecure backup of the SQLite database
- **Inherent risk:** ⬆ Critical
 - **Current risk:** 🚩 Critical
 - **Projected risk:** ⬆ Critical
 - **State:** Exposed
 - **CR113. Countermeasure name:** Implement secure backup procedures with encryption and access controls
 - **Status:** RECOMMENDED

- CRT88. Threat name:** Data leakage due to unencrypted SQLite database file
- **Inherent risk:** ⬆ High
 - **Current risk:** 🚩 High
 - **Projected risk:** ⬆ High
 - **State:** Exposed
 - **CR114. Countermeasure name:** Encrypt the SQLite database file (e.g., using SQLCipher)
 - **Status:** RECOMMENDED

End of Current Risk Report

